



DESARROLLO DE SOFTWARE MULTIPLATAFORMA

DESARROLLO WEB PROFESIONAL

ABRAHAM CERVANTES ROMERO

8º CUATRIMESTRE GRUPO "A"

Recuperación de contraseñas accesible y segura

1. ¿Qué es un token de recuperación?

Un **token de recuperación** es un código único y temporal que se genera cuando el usuario solicita recuperar su contraseña.

Funciona como una “llave digital” para comprobar que el usuario tiene acceso a su correo.

Ejemplo de token:

a8f9K2IP0xYz

Flujo básico:

1. Usuario da clic en “Olvidé mi contraseña”
2. Ingresa su correo
3. El sistema genera un token
4. Se envía un enlace con ese token
5. Usuario crea nueva contraseña

Ejemplo de enlace:

<https://miapp.com/reset?token=abc123>

2. ¿Por qué deben expirar los tokens?

Los tokens deben tener **tiempo limitado** por seguridad.

Ejemplo:

- Válido por 15 minutos o 1 hora

¿Por qué?

Si no expiran:

- ✗ alguien podría usarlo después
- ✗ riesgo de hackeo
- ✗ acceso no autorizado

Beneficios de expirar tokens:

- ✓ reduce ataques
- ✓ protege cuentas
- ✓ limita tiempo de uso

3. ¿Qué ataques existen en recuperación de contraseña?

Este flujo es **muy vulnerable**, por eso es importante protegerlo.

1. Ataque de enumeración de usuarios

Cuando el sistema dice:

El correo no existe

☞ el atacante descubre qué cuentas están registradas

Solución:

Mostrar siempre:

Si el correo existe, recibirás instrucciones

2. Ataque de fuerza bruta al token

Intentar adivinar el token.

Solución:

- ✓ tokens largos y aleatorios
- ✓ límite de intentos

3. Ataque de phishing

Correos falsos que simulan recuperación.

✓ Solución:

- ✓ usar correos oficiales
- ✓ enlaces seguros (https)

4. Reutilización de token

Usar el mismo token varias veces.

Solución:

- ✓ token de un solo uso
- ✓ invalidarlo después

5. Token sin expiración

El token sigue funcionando por días.

✗ muy inseguro

4. ¿Cómo diseñar un flujo accesible?

Debe ser fácil de usar para **todas las personas** 

Accesibilidad en el formulario

- ✓ etiquetas claras
- ✓ mensajes simples
- ✓ compatible con teclado
- ✓ lectores de pantalla

Ejemplo de formulario accesible:

```
<label for="email">Correo electrónico</label>  
<input id="email" type="email" required>
```

```
<button type="submit">Recuperar contraseña</button>
```

Mensajes accesibles

✗ Malo:

Error 500

✓ Bueno:

Revisa tu correo para continuar con la recuperación

Uso con teclado

- ✓ TAB para navegar
- ✓ ENTER para enviar
- ✓ enfoque visible

Flujo claro para el usuario

1. Solicita recuperación
2. Recibe correo
3. Da clic en enlace

4. Cambia contraseña
5. Confirma cambio

5. Buen flujo seguro

Paso a paso ideal:

1 Usuario escribe correo

2 Sistema responde:

Si el correo está registrado, recibirás un enlace

3 Se genera token:

- único
- aleatorio
- con expiración

4 Se envía enlace seguro

5 Usuario abre enlace

6 Ingresa nueva contraseña

7 Token se invalida

6. Buenas prácticas de seguridad

- ✓ Usar HTTPS
- ✓ Tokens largos (mínimo 32 caracteres)
- ✓ Expiración corta
- ✓ Un solo uso
- ✓ No mostrar información sensible
- ✓ Registrar intentos (logs)
- ✓ Limitar solicitudes (anti spam)

7. ¿Para qué sirve todo esto?

Puedes decirlo así:

La recuperación de contraseña es un punto crítico de seguridad porque permite acceder a cuentas sin contraseña. Por eso se utilizan tokens temporales, seguros y de un solo uso, además de un diseño accesible que permita a cualquier usuario recuperar su acceso sin comprometer la seguridad del sistema.